If you have received an application where the secret was exposed (e.g. an application whose source was shared), strongly consider changing the secret.

2.6 Replay Attacks for CookieStore Sessions

Another sort of attack you have to be aware of when using `CookieStore` is the replay attack.

It works like this:

- A user receives credits, the amount is stored in a session (which is a bad idea anyway, but we'll do this for demonstration purposes).
- The user buys something.
- The new adjusted credit value is stored in the session.
- The user takes the cookie from the first step (which they previously copied) and replaces the current cookie in the browser.
- The user has their original credit back.

Including a nonce (a random value) in the session solves replay attacks. A nonce is valid only once, and the server has to keep track of all the valid nonces. It gets even more complicated if you have several application servers (mongrels). Storing nonces in a database table would defeat the entire purpose of CookieStore (avoiding accessing the database).

The best *solution against it is not to store this kind of data in a session, but in the database*. In this case store the credit in the database and the logged_in_user_id in the session.

2.7 Session Fixation

Apart from stealing a user's session id, the attacker may fix a session id known to them. This is called session fixation.

